Báo cáo Tuần 1

I. Worklog

Nguyễn Xuân Nhật (MSSV: 24110293)

• Phác thảo và vẽ sơ đồ kiến trúc tổng thể bằng draw.io.

• Tạo VPC Lab-VPC (CIDR 10.0.0.0/16) trên AWS Management Console, 2 Public Subnets và 2 Private App Subnets trên 2 AZ (us-east-1a, us-east-1b).

• Cấu hình Internet Gateway (Lab-VPC-igw), Route Tables và S3 Gateway Endpoint (Lab-VPC-vpce-s3).

• Khởi tạo S3 Bucket sec-app-logs-24110293-24110168-us-east-1. Bật tính năng Block All Public Access và mã hóa mặc định SSE-S3.

• Gắn nhãn Tagging (Project, Owner, Environment) cho VPC và S3 bucket.

Nguyễn Công Bình (MSSV: 24110168)

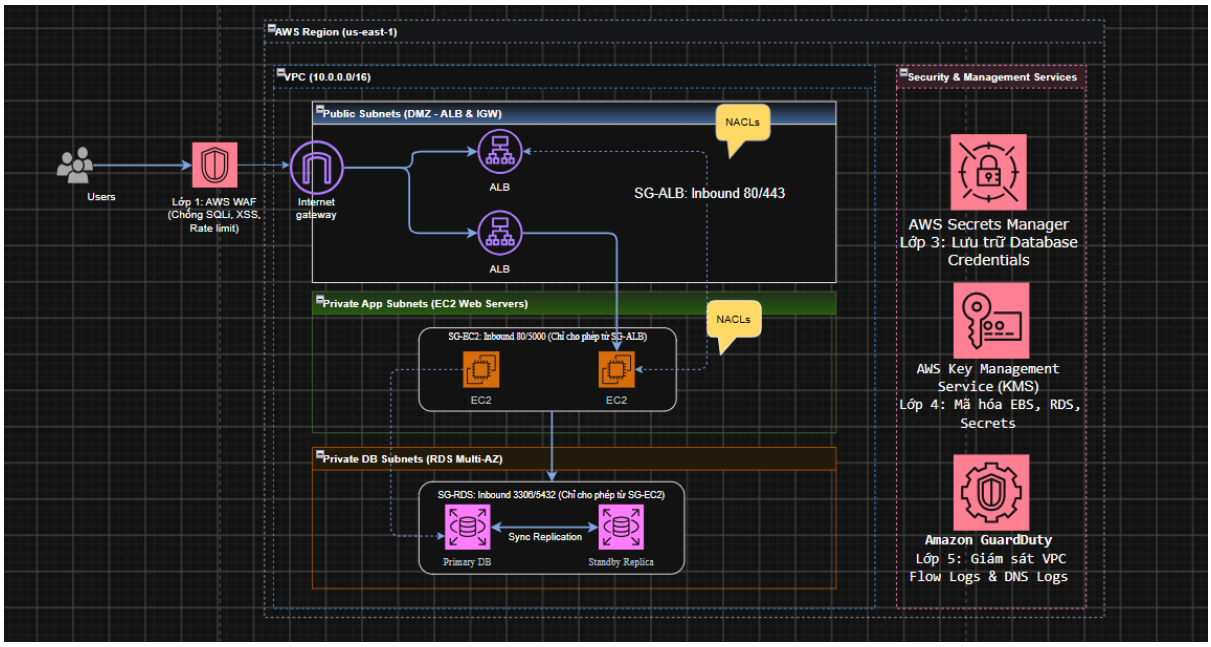
• Nghiên cứu và soạn thảo bản dự thảo tài liệu Threat Modeling phân tích chi tiết 6 khía cạnh: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege.

• Khảo sát danh sách quyền của LabRole và LabInstanceProfile trên IAM Console.

• Cấu hình 3 Security Groups liên kết chặt chẽ.

• Thiết lập Git repository chung cho nhóm trên GitHub.

II. Sơ đồ kiến trúc



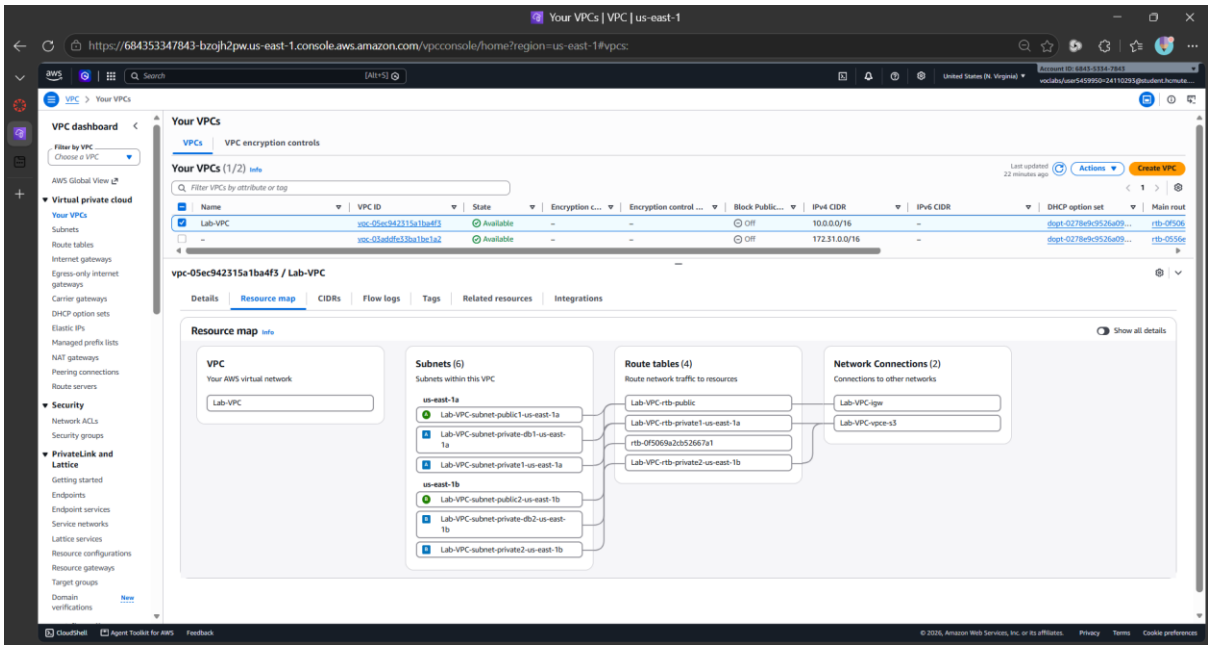
III. STRIDE Model

Spoofing *(Giả mạo danh tính)*	ALB (Public Entry) EC2 Web App	Kẻ tấn công giả mạo địa chỉ IP, giả mạo Client hoặc giả lập các HTTP request hợp lệ để truy cập tài nguyên nội bộ trái phép.	**AWS WAF:** Lọc header giả mạo, kiểm tra IP Reputation List. **NACL & Security Group:** Chỉ cho phép traffic đi qua ALB hợp lệ; EC2 chỉ nhận traffic từ ALB.
Tampering *(Can thiệp / Sửa đổi dữ liệu)*	Dữ liệu truyền tải (In-transit) Dữ liệu lưu trữ (At-rest: EBS, RDS, S3)	Man-in-the-Middle (MitM) nghe lén hoặc sửa đổi gói tin HTTP. Kẻ xấu/mã độc sửa đổi trái phép dữ liệu trong DB hoặc file log trên S3.	**HTTPS / TLS:** Mã hóa đường truyền từ Client đến ALB. **AWS KMS:** Mã hóa toàn bộ volume EBS, database RDS và S3 Bucket (SSE-KMS/SSE-S3). **S3 Versioning / Object Lock:** Chống xóa, chống sửa đổi log.
Repudiation *(Chối bỏ trách nhiệm)*	Toàn bộ hệ thống (ALB,EC2,Database)	Kẻ tấn công hoặc người dùng nội bộ thực hiện hành vi phá hoại/truy vấn độc hại nhưng không lưu lại vết để điều tra và quy trách nhiệm.	**Amazon GuardDuty:** Giám sát liên tục VPC Flow Logs và DNS query logs để phát hiện hành vi bất thường. **ALB Access Logs & S3:** Bật logging toàn bộ request chuyển tiếp về S3. **CloudWatch Logs:** Ghi log hoạt động của ứng dụng.
Information Disclosure *(Lộ lọt thông tin)*	ALB EC2 Compute Instance	Kẻ tấn công gửi hàng triệu request liên tục (HTTP Flood) làm cạn kiệt tài nguyên CPU/RAM của EC2 hoặc làm sập đường truyền mạng.	**AWS WAF Rate-based Rule:** Tự động chặn tạm thời bất kỳ IP nào gửi vượt quá ngưỡng (ví dụ: > 100 requests / 5 phút). **AWS Shield Standard:** Mặc định bảo vệ chống DDoS tầng L3/L4 cho ALB. **ALB Distribution:**

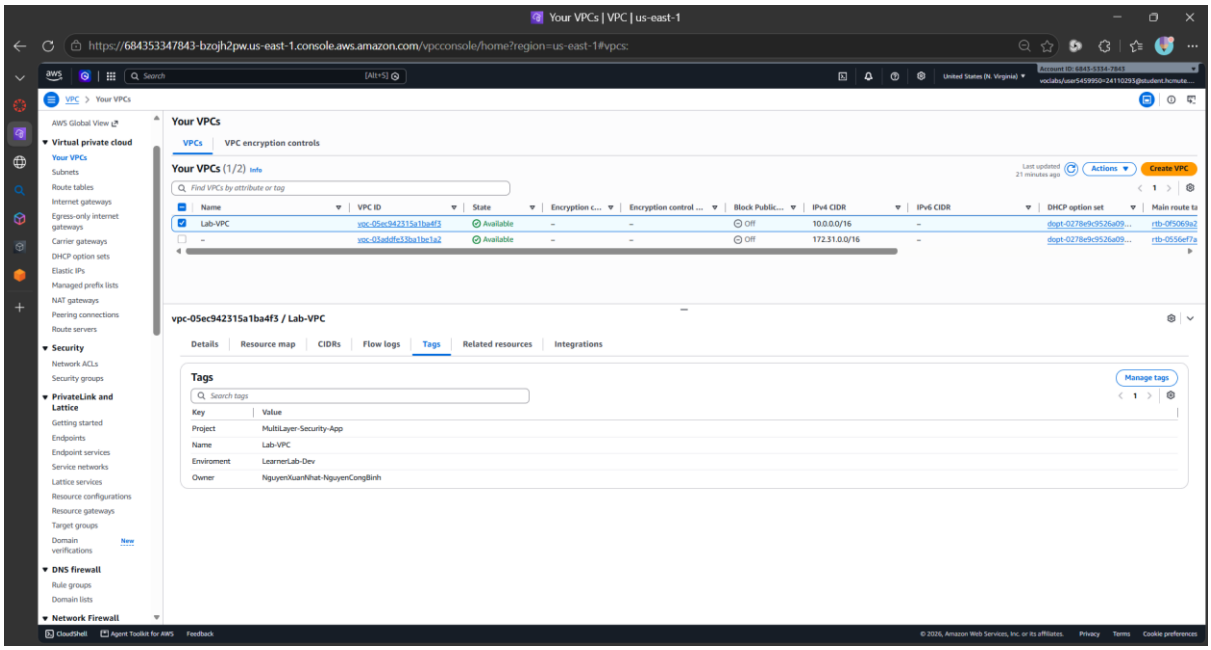
			Phân phối tải đều qua các AZs.
Elevation of Privilege *(Leo thang đặc quyền)*	Máy chủ EC2 Quyền IAM trên AWS	Kẻ tấn công chiếm được shell trên EC2, sau đó tìm cách chiếm quyền Root hệ điều hành hoặc lấy cắp AWS Token để thao túng các tài nguyên đám mây khác.	**IAM LabRole / LabInstanceProfile:** Chỉ gán quyền tối thiểu cần thiết cho EC2 (Principle of Least Privilege). **Security Group EC2:** Chặn mở SSH (port 22) ra ngoài Internet, chỉ quản lý qua EC2 Instance Connect / SSM nếu cần. **Security Group RDS:** Chỉ chấp nhận duy nhất Inbound kết nối từ SG-EC2.

IV. Dựng nền tảng

Lab-VPC

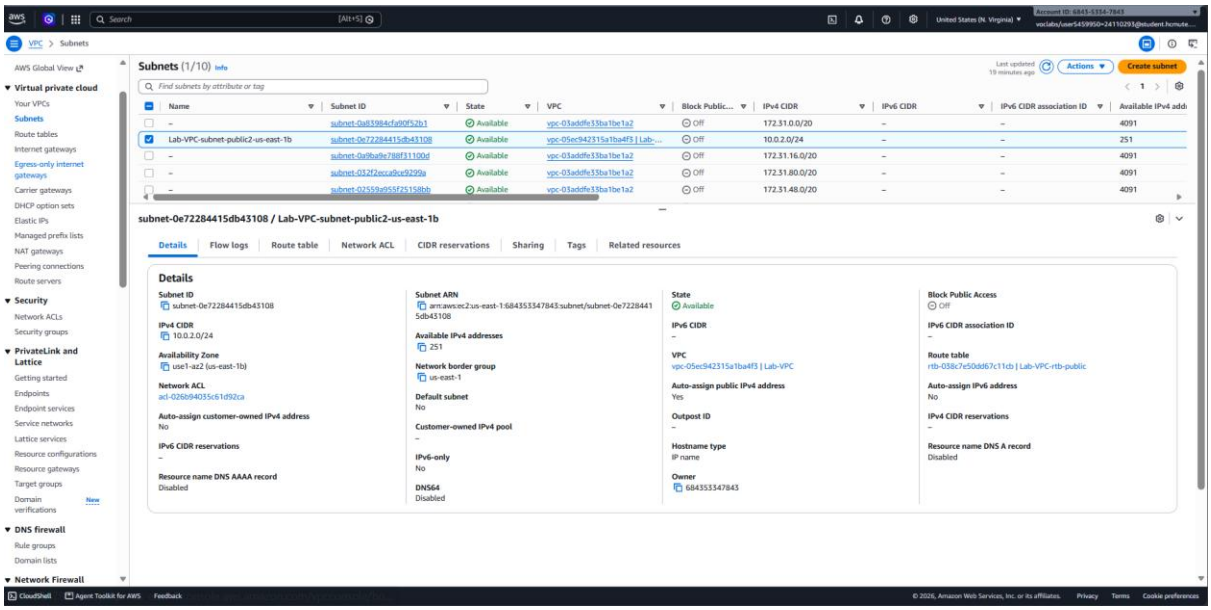


Tags VPC:

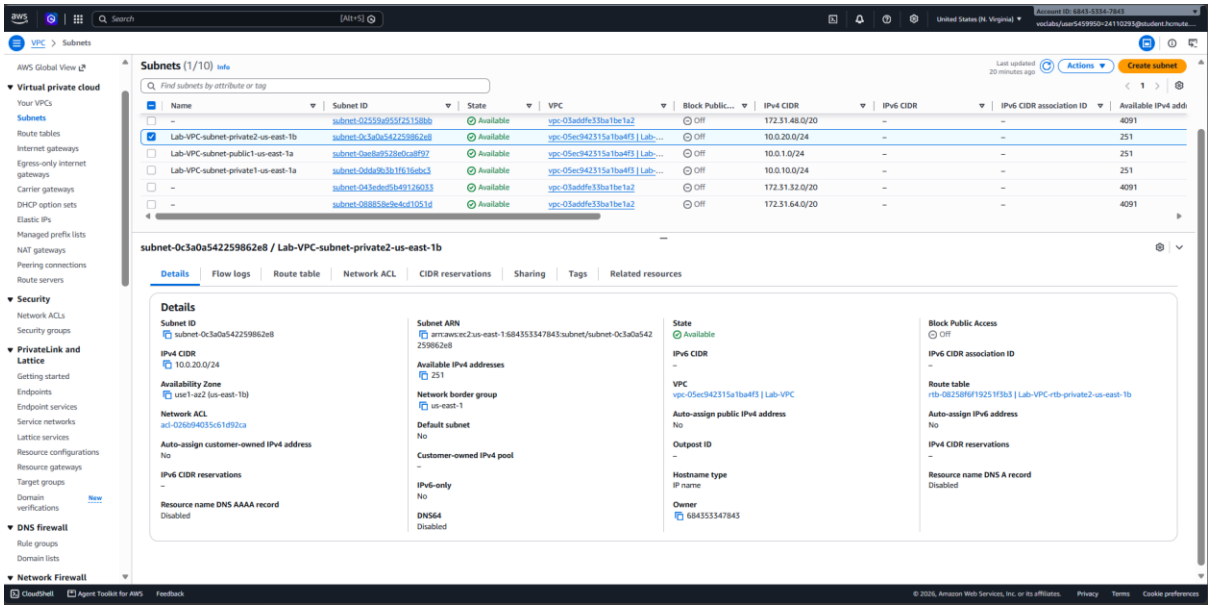


Subnets

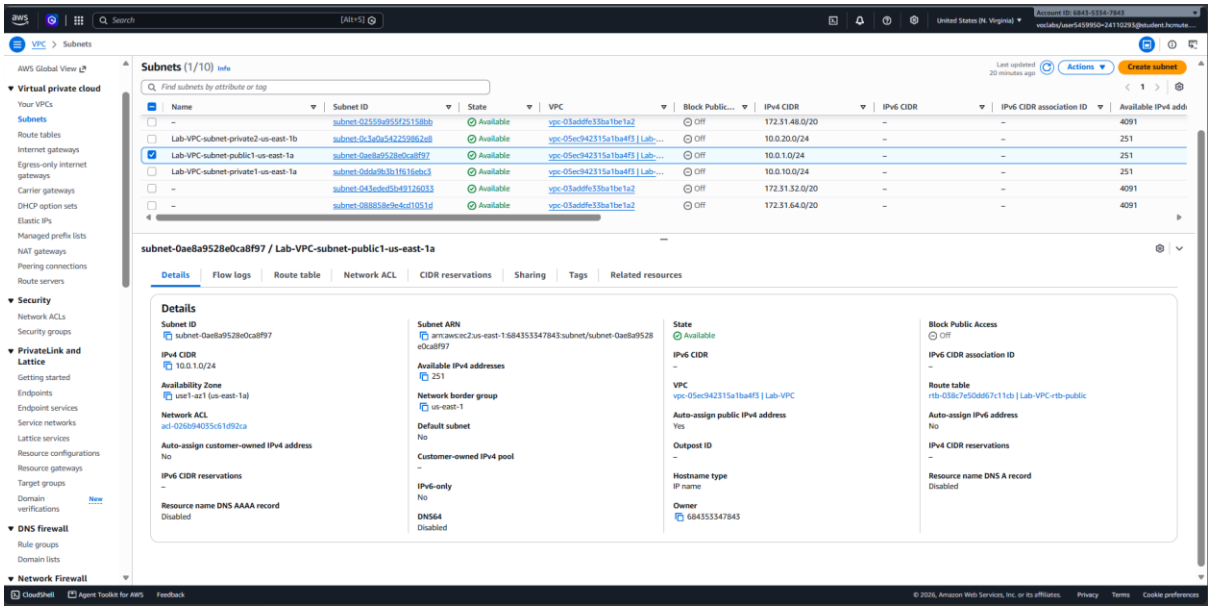
Lab-VPC-subnet-public2-us-east-1b:



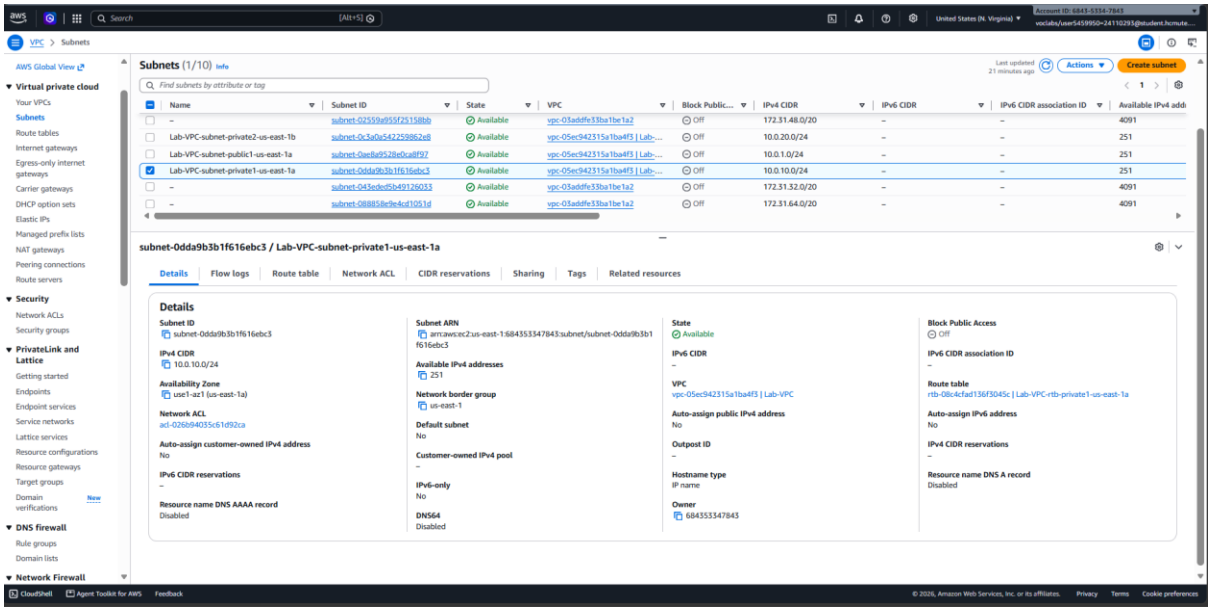
Lab-VPC-subnet-private2-us-east-1b:



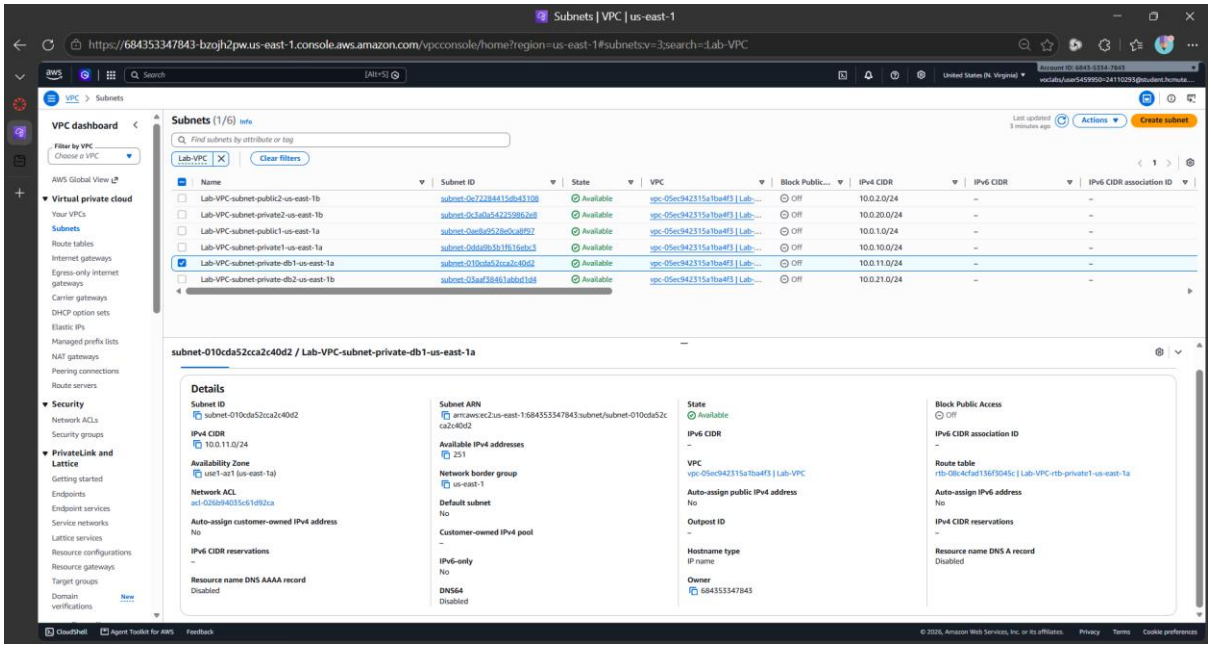
Lab-VPC-subnet-public1-us-east-1a:



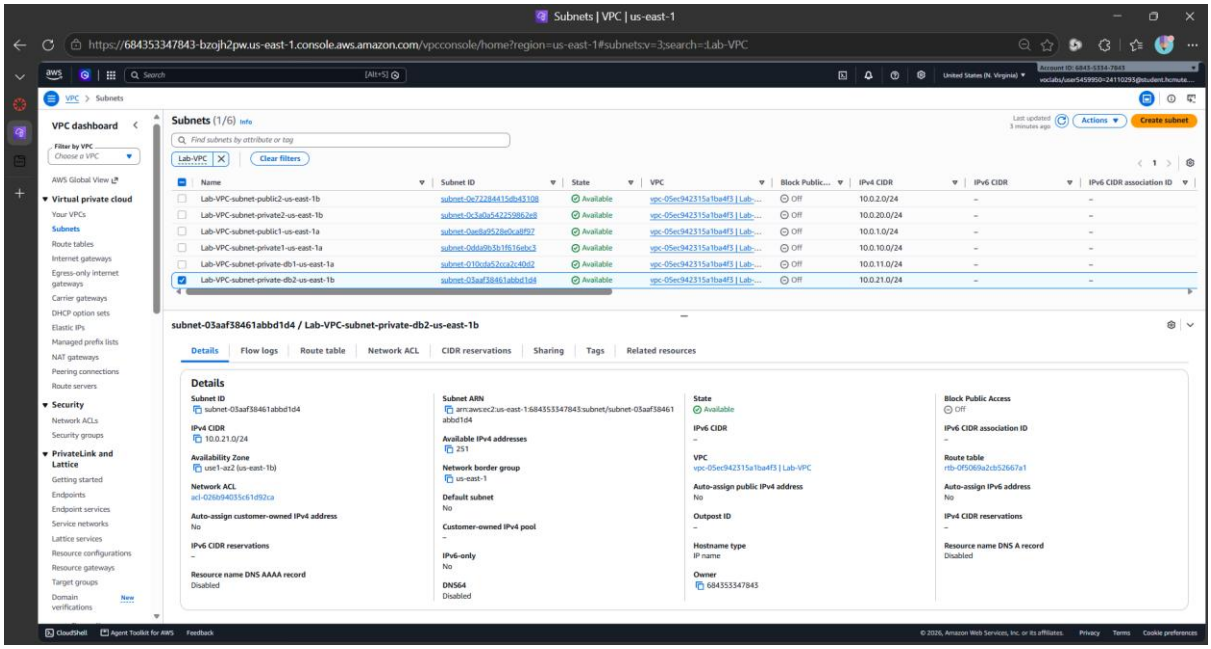
Lab-VPC-subnet-private1-us-east-1a:



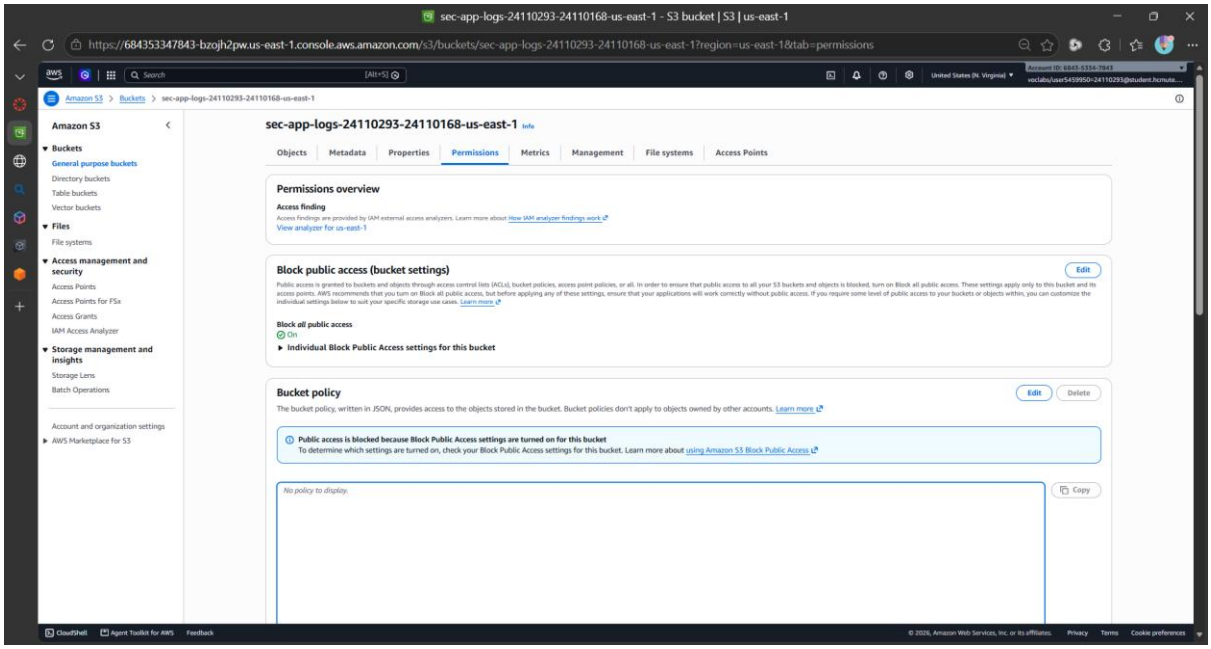
Lab-VPC-subnet-private-db1-us-east-1a:

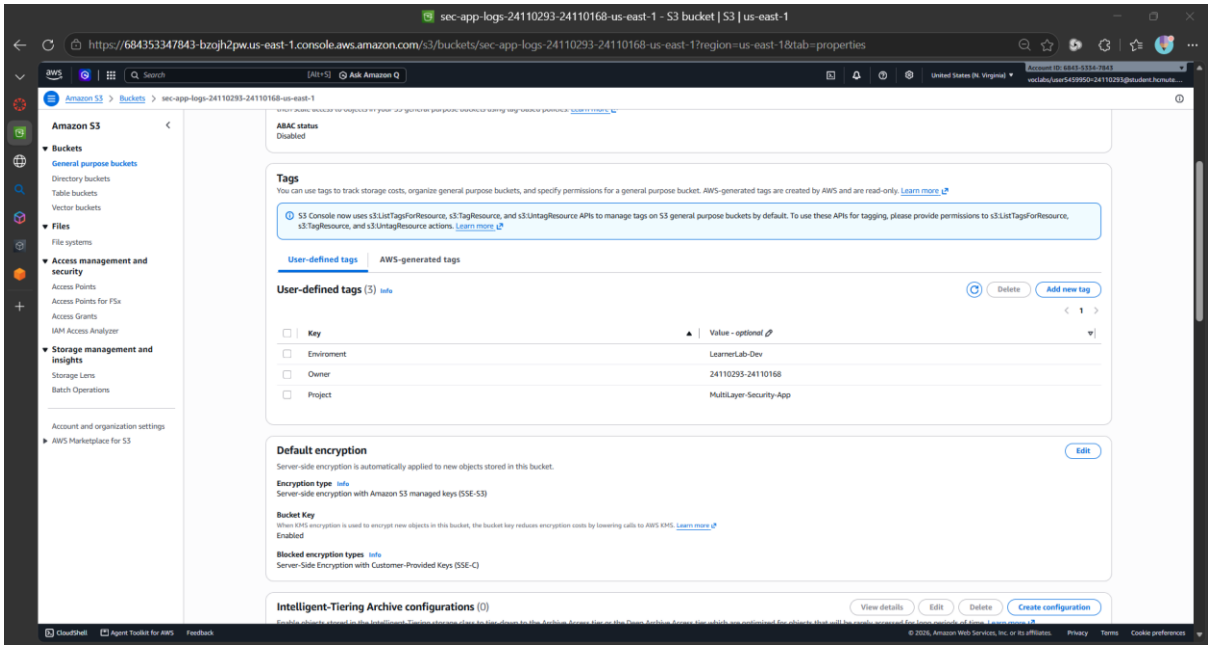


Lab-VPC-subnet-private-db2-us-east-1b:

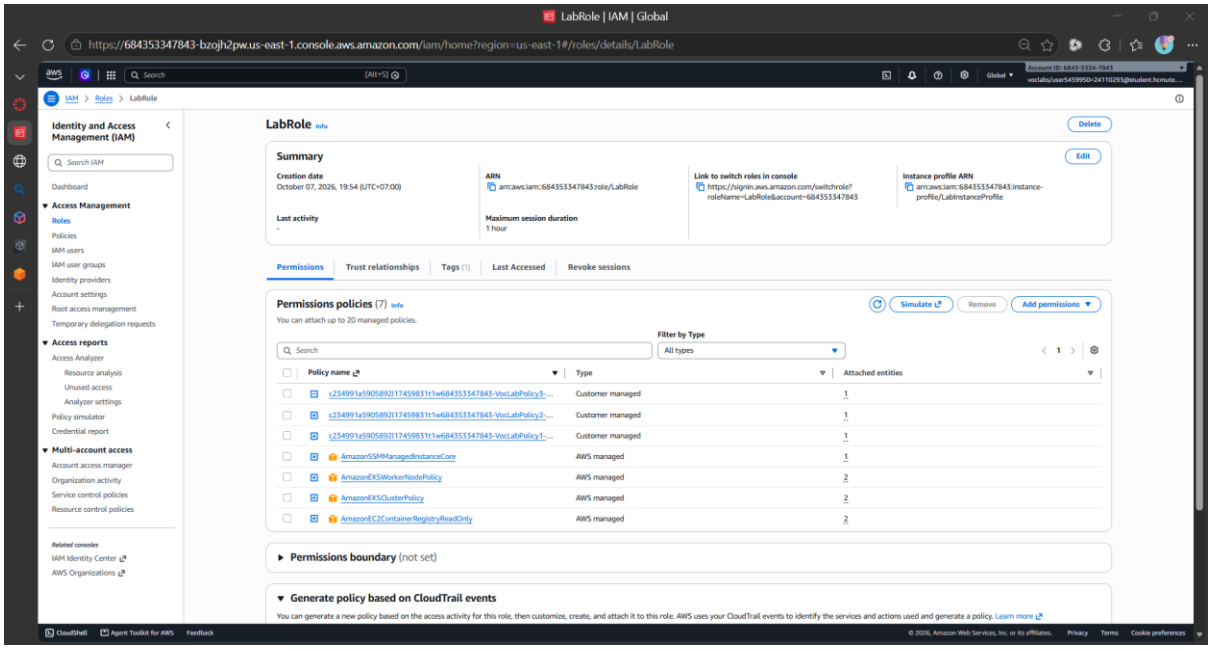


S3 đã bật mã hóa và gắn tag

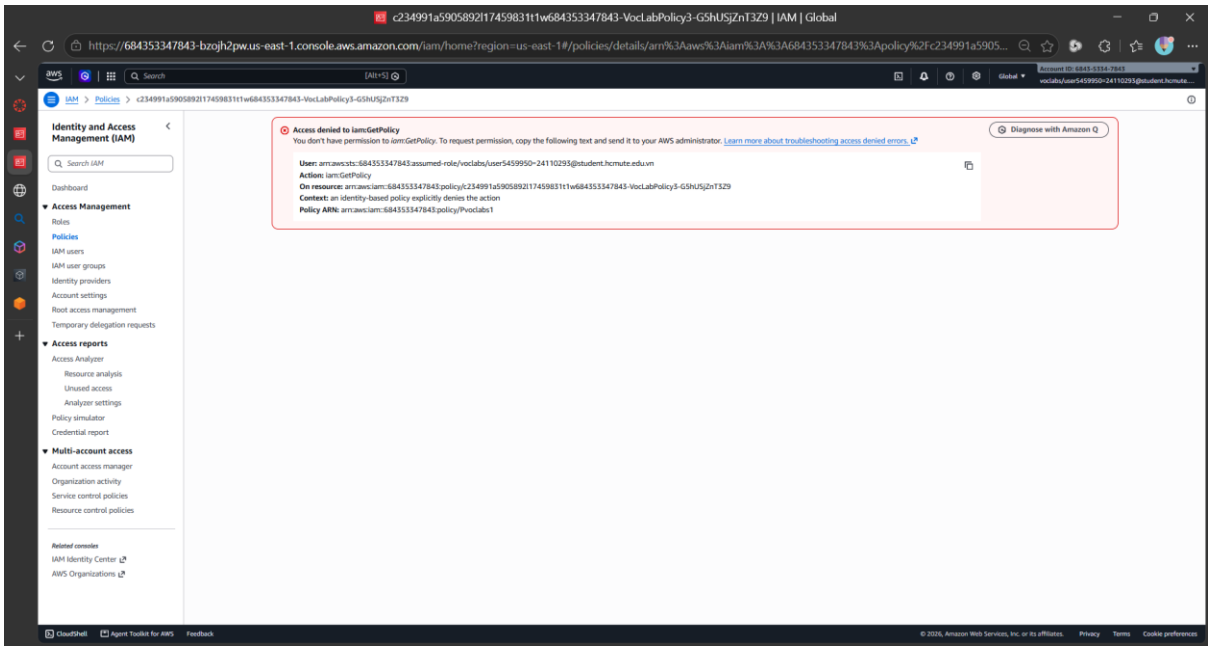




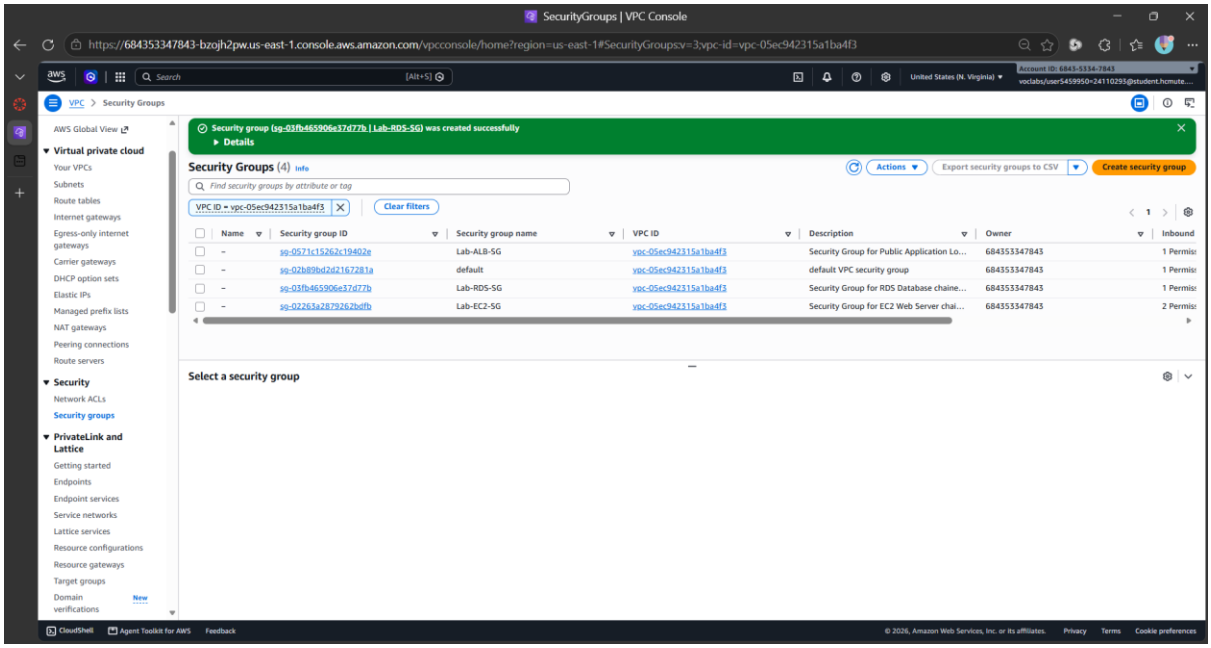
IAM LabRole



Instance Profile ARN: arn:aws:iam::684353347843:instance-profile/LabInstanceProfile
(được dùng để gắn trực tiếp vào các máy ảo EC2 sau này nhằm cấp quyền mà không cần lưu trữ cứng AWS Access Keys trong source code).

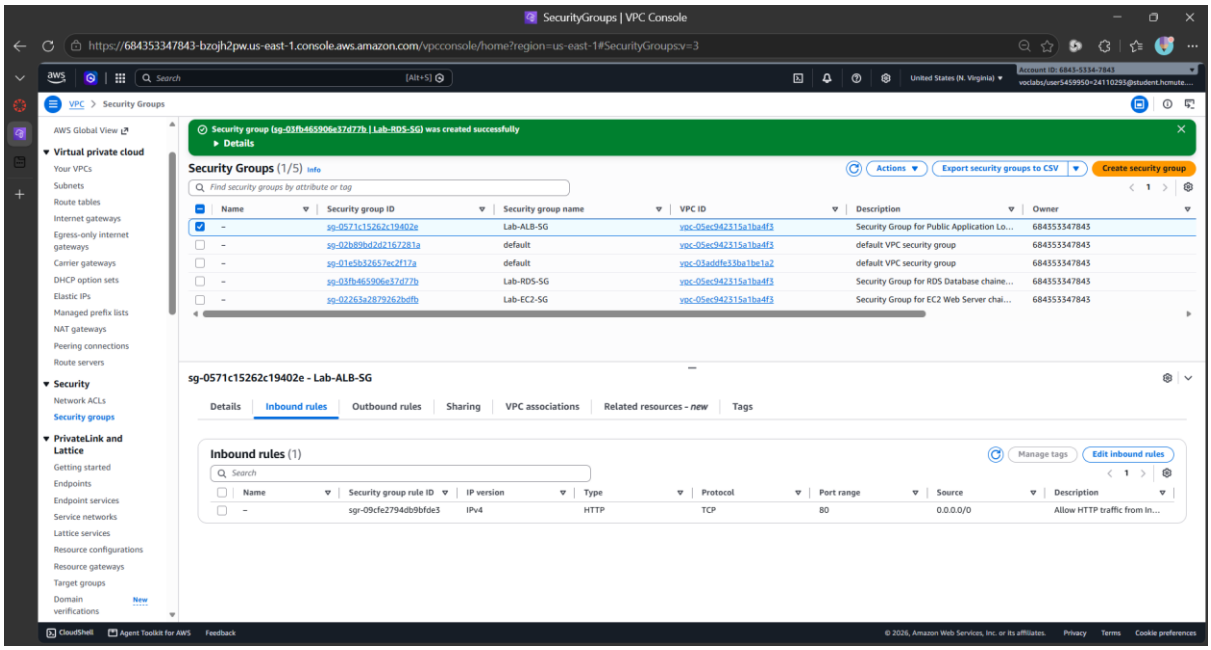


Nhóm em đã tiến hành khảo sát và mở chi tiết các chính sách VocLabPolicy1-3 trong LabRole. Tuy nhiên, do môi trường AWS Learner Lab áp dụng SCP/Boundary Pvoclabs1 cấm quyền iam:GetPolicy đối với người dùng đăng nhập nhằm bảo vệ cấu hình nội bộ của Vocareum, sinh viên không thể đọc trực tiếp nội dung JSON qua Console. Dù vậy, tên và sự hiện diện của 3 policies này (VocLabPolicy1/2/3) cùng AmazonSSMManagedInstanceCore xác nhận vai trò đã được nạp sẵn quyền hạn cho các dịch vụ cốt lõi


SecurityGroups | VPC Console
https://684353347843-bzojh2pw.us-east-1.console.aws.amazon.com/vpcconsole/home?region=us-east-1#SecurityGroups:v=3;vpc-id=vpc-05ec942315a1ba4f3
Search
[Alt+S]
United States (N. Virginia)
Account ID: 6843-5334-7843
voclabs/user5459950=24110293@student.hcmute....
VPC > Security Groups
AWS Global View
Virtual private cloud
Your VPCs
Subnets
Route tables
Internet gateways
Egress-only internet gateways
Carrier gateways
DHCP option sets
Elastic IPs
Managed prefix lists
NAT gateways
Peering connections
Route servers
Security
Network ACLs
Security groups
PrivateLink and Lattice
Getting started
Endpoints
Endpoint services
Service networks
Lattice services
Resource configurations
Resource gateways
Target groups
Domain verifications
New
Security group (sg-03fb465906e37d77b | Lab-RDS-SG) was created successfully
Details
Security Groups (4) Info
Find security groups by attribute or tag
Actions
Export security groups to CSV
Create security group
VPC ID = vpc-05ec942315a1ba4f3
Clear filters
Name
Security group ID
Security group name
VPC ID
Description
Owner
Inbound
sg-0571c15262c19402e
Lab-ALB-SG
vpc-05ec942315a1ba4f3
Security Group for Public Application Lo...
684353347843
1 Permis
sg-02b89bd2d2167281a
default
vpc-05ec942315a1ba4f3
default VPC security group
684353347843
1 Permis
sg-03fb465906e37d77b
Lab-RDS-SG
vpc-05ec942315a1ba4f3
Security Group for RDS Database chaine...
684353347843
1 Permis
sg-02263a2879262bdfb
Lab-EC2-SG
vpc-05ec942315a1ba4f3
Security Group for EC2 Web Server chai...
684353347843
2 Permis
Select a security group
CloudShell
Agent Toolkit for AWS
Feedback
© 2026, Amazon Web Services, Inc. or its affiliates.
Privacy
Terms
Cookie preferences

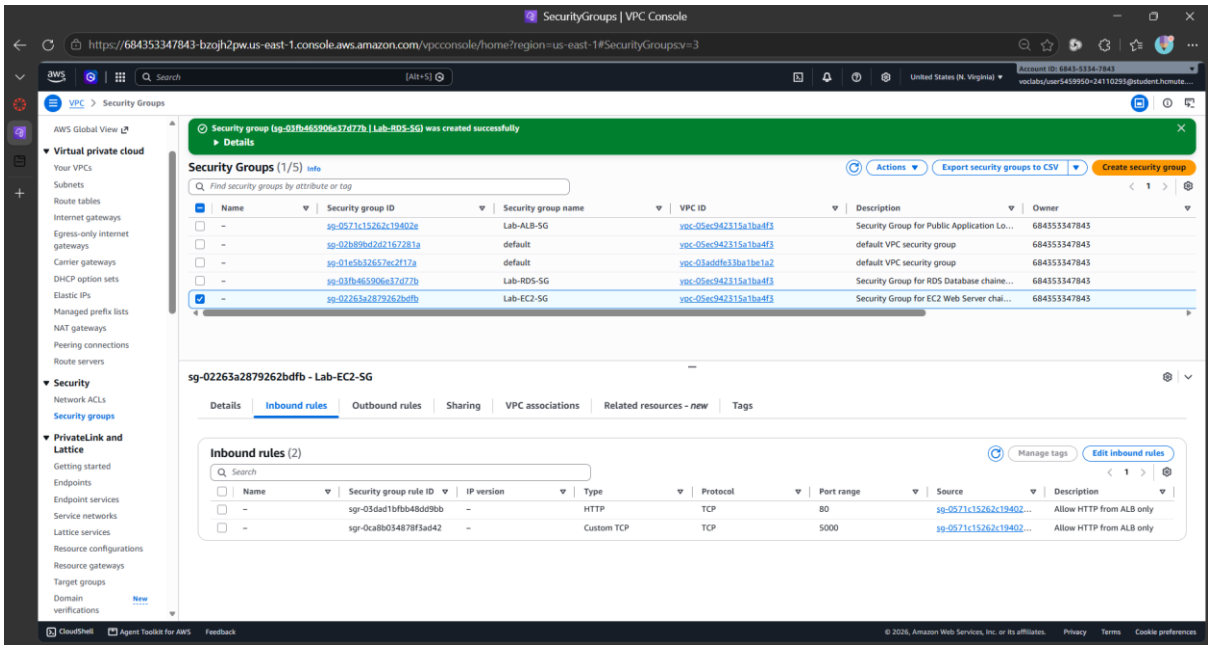
Cấu hình Security Group Chaining phân tầng bảo vệ trong Lab-VPC

Ảnh Lab-ALB-SG:



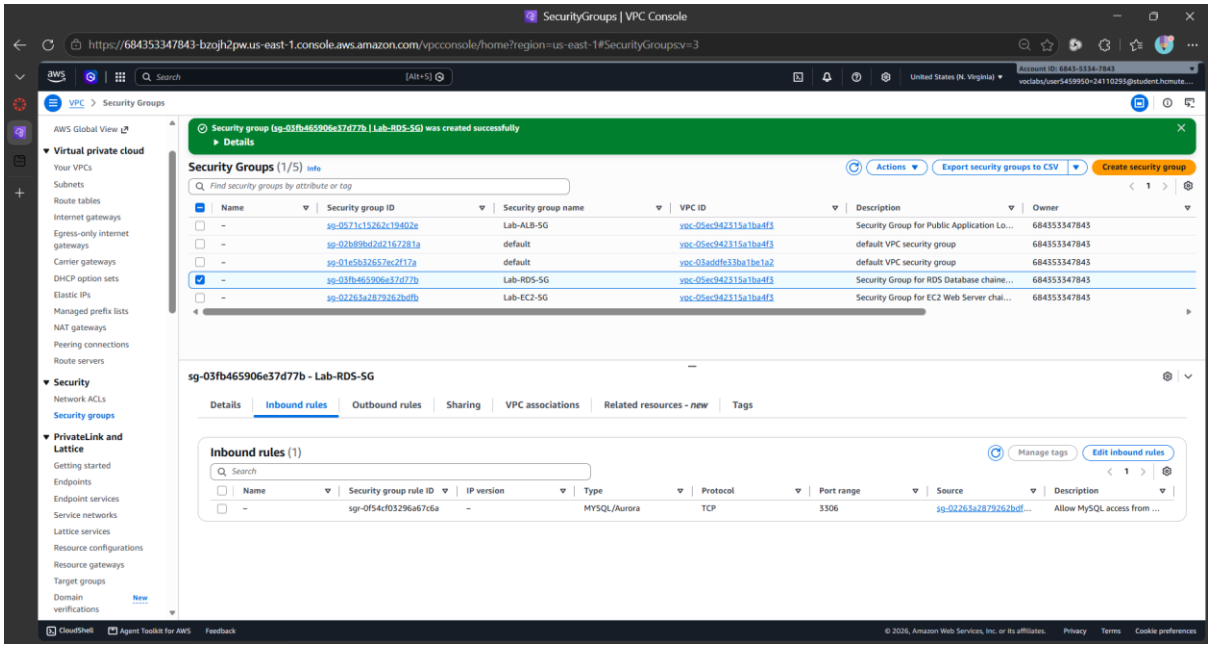
Lab-ALB-SG (Tầng biên): *Chỉ mở cổng HTTP (Port 80) tiếp nhận lưu lượng từ Internet (0.0.0.0/0).*

Ảnh Lab-EC2-SG:



Lab-EC2-SG (Tầng ứng dụng): *Áp dụng nguyên tắc đặc quyền tối thiểu (Least Privilege), tuyệt đối không mở cổng ra Internet (0.0.0.0/0), mà chỉ cho phép lưu lượng truy cập Inbound từ chính*

Ảnh Lab-RDS-SG:



Lab-RDS-SG (Tầng cơ sở dữ liệu): *Nằm cô lập trong Private Subnet và chỉ chấp nhận kết nối TCP qua cổng 3306 có nguồn gốc xác thực từ Lab-EC2-SG. Kẻ tấn công cho dù tiếp cận được dải mạng nội bộ cũng không thể truy cập trực tiếp vào Database nếu không xuất phát từ máy chủ ứng dụng hợp lệ.*